



Fortinet Cybersecurity Academy – Configuring a WPA2 and WPA2 Enterprise Wireless Local Area Network with a RADIUS Server

Yuuki Burleigh – CCNA, AWS CCP

Purpose

This lab develops an understanding of how enterprise level wireless local area network (WLAN) systems work through the practice of setting up both a standard WPA2 WLAN and an enterprise level WLAN. The lab additionally teaches the practical skills of configuring and setting up a WLAN through real hands-on practice with a FortiGate-40F firewall. It additionally teaches user management and authentication practices through configuring a RADIUS server to manage user credentials and their authentication for the enterprise level WLAN.

Background

A WLAN or Wireless Area Network is a local network that does not need wires to transmit information and connectivity to endpoints. WLAN instead uses radio transmissions instead of electrical signals through wires. This provides the ability to increase productivity in an organization or everyday life through increased access to the internet and higher levels of convenience. A typical network setup for a WLAN includes a wireless router that connects to an ISP (Internet Service Provider), or an access point that is connected to a WLAN controller. Typical household environments use wireless routers as they provide enough coverage over the entire household to provide internet access to any location within the house. In larger and more corporate settings many organizations opt for the use of multiple access points and a centralized control device like a WLAN controller. This is because a wireless router can only provide a limited range of internet access due to signal attenuation and interference the farther the signal strays from its origin. Having access points allows for the signal to travel further acting as checkpoints for a weak signal to be relayed again from a point farther from its origin allowing for extended reach and increased levels of access to the same WLAN network. In this setup typically the access points are wired and connected to a central point called a WLAN Controller which is responsible for enforcing WLAN policies and routing information to and from the endpoints connected to the WLAN.

Because a WLAN provides more convenient access to a network makes it significantly more vulnerable to attacks compared to a wired network. In a wired network an attacker would have to have a physical connection to attack a network, while in a WLAN connecting to the network is much easier as access can be attained anywhere the radio frequencies reach. To secure the WLAN, authentication methods like Wired Equivalent Privacy (WEP) and Wi-Fi Protected Access (WPA) have been created with WPA3 Enterprise being the most secure and WPA2 Enterprise used the most. As WPA2 Enterprise works through the 802.1X to authenticate users to secure a wireless network. 802.1X authentication has three major parts, the Supplicant (client/end user), Authenticator (Access Point), and an Authentication Server (Typically a RADIUS server). The supplicant refers to the devices trying to connect to an 802.1X network and initiates the connection through EAP or an Extensible Authentication Protocol transaction with the controller or switch, the supplicant sends its credentials legible by 802.1X. An Authenticator refers to the device that supplies the data links connecting the network and the client it can block traffic between an endpoint and the network. Finally, an authentication server is the device that receives the access

request to a network and responds to them. It tells the authenticator to accept or deny connection requests and the settings that the user must follow for connectivity to the network. These three parts interact in a specific order to provide a secure connection and begin with the initiation phase. During the initiation phase the authenticator sends and EAP (Extensible Authentication Protocol) request identity frames that are used to request the identity of the device trying to connect to the network. This request is sent using a MAC address and once the information requested is received from the device with said address, the authenticator then packages that information and sends it to the authentication server for authentication. Next is the Authentication stage, once the supplicant's identity information is sent to the authentication server the server responds with a success or failure message, if successful the port to the endpoint is then designated as an authorized port enabling normal traffic to pass, while during failure the port is designated as unauthorized resulting in all non-EAP or authentication traffic to be blocked. But before the supplicant is allowed access to the network it needs to be authorized, the authentication server then checks the identity credentials and certificate validity before authorizing the user for network access, this part is essentially how the authentication server authenticates and determines a success or failure.

Alongside Authentication, WPA2 additionally uses encryption to encrypt data in transit. WPA2 supports CCMP which is an AES-based encryption mode. CCMP scrambles data traveling between the endpoint and the access point so that the data is unreadable to other devices if intercepted. CCMP also verifies that the information has not been altered to ensure data integrity and protect against tampering. AES is a form of encryption algorithm that is widely used and trusted globally. But before this data is encrypted a four-way handshake must occur after authentication. During authentication a Master Session Key is generated, depending on the method of EAP (Extensible Authentication Protocol) the way the MSK (Master Session Key) is different but the idea is that a complex math problem involving random numbers (Nonces), public keys, and private keys are performed to get the same value but only exchanging the Nonces and public keys. From this MSK a PMK (Pairwise Master Key) is established using the first 32 bits of the MSK. Using the PSK, nonces are exchanged again along with MAC-addresses to create a PTK which the AP uses to encrypt a message to query a response from the client. If the client derives the same PTK and replies the encrypted connection is successful and the WLAN is secured through means of WPA2-Enterprise.

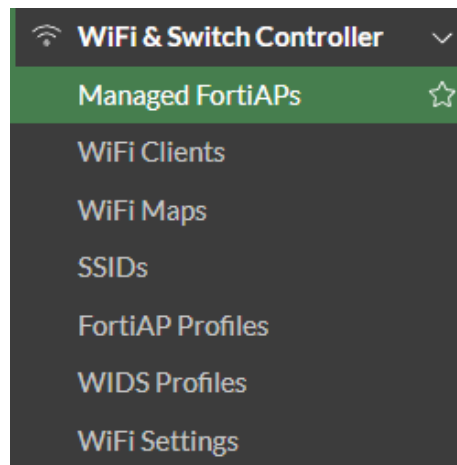
Lab Summary

In this lab a WLAN is set up using a Fortinet Access Point using both WPA2 and WPA2 Enterprise. The lab walks through the steps of setting a normal WPA2 WLAN using a pre-shared key, then building off that knowledge setting up a WPA2-Enterprise WLAN that uses a Remote Authentication Dial-In Service (RADUIS) service to authenticate and authorize users.

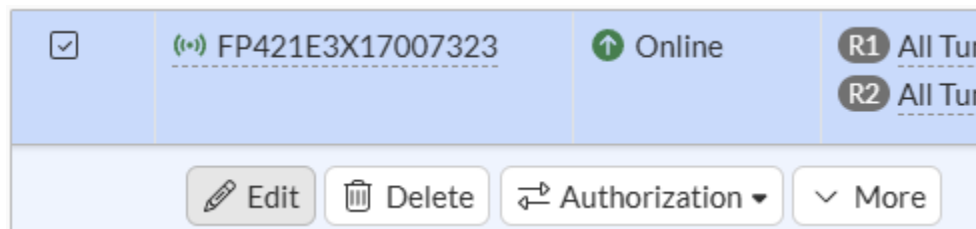
Lab Commands

Physically connect an FortiAP to the FortiGate firewall.

Login to the firewall at the management port, default is 192.168.1.99. Navigate to "WiFi & Switch Controller" > "Managed FortiAPs".



Notice that the AP that was just connected is now listed. Select it and press “Edit”.



Authorize the device and name it.

Serial number FP421E3X17007323

Name

Location

Comments 0/255

Status

Now Navigate to “WiFi & Switch Controller” > “SSIDs”. Create an SSID using the Create button. Configure the following:

- Under WiFi Settings name the SSID
- Enable Broadcasting
- Selecting WPA2 Personal as the Security Mode
- Configure the Password/Pre-Shared Key

WiFi Settings

SSID

Client limit ⓘ ☐

Broadcast SSID ☒

Beacon advertising ☒ Name

☐ Model

☐ Serial number

Security Mode Settings

Security mode

Captive Portal ☐

Pre-shared Key

Mode ⓘ ☒ Single ☐ Multiple

Passphrase ⓘ ⓘ

Under Addressing:
Set a non-overlapping IP address Range.
Create a Matching object for that address range.

Addressing mode ☒ Manual ☐ IPAM

IP/Netmask

Create address object matching subnet ☒

Name

Destination

Secondary IP address ☐

Under DHCP Server
Enable it.
Select a non-overlapping address range.
Default Gateway: Same as interface IP.
DNS Server: Same as System DNS
Leave Lease Time to default.

☒ DHCP Server

DHCP status

↑ Enabled

↓ Disabled

Address range

10.0.0.2-10.0.0.254

+

Netmask

255.255.255.0

Default gateway

Same as Interface IP

Specify

DNS server

Same as System DNS

Same as Interface IP

Specify

Lease time ⓘ ☒

604800

second(s)

☒ Advanced

Navigate back to the managed FortiAPs tab and edit the AP you've named. Under Override Radio One or Two, enable it and manually select an SSID and select the one you've created.

Override Radio 2

Band

☒ 5 GHz 802.11ac/n/a

5 GHz

802.11ac

802.11n

802.11a

+

Channels

☒ (Automatically assigned)

Set Channels

36 40 44 48 52 56 60 64

100 104 108 112 116 120 124 128

132 136 140 144 149 153 157 161

Transmit power mode

☒ 100%

☒ Percent

Transmit power is determined by multiplying set percentage with maximum available power determined by region and FortiAP device.

☐ dBm

Power is setting using a dBm value.

☐ Auto

Set a range of dBm values and the power is set automatically.

Transmit power

100 %

SSIDs

☒ (Automatically assign Tunnel mode SSIDs)

🔌 Tunnel

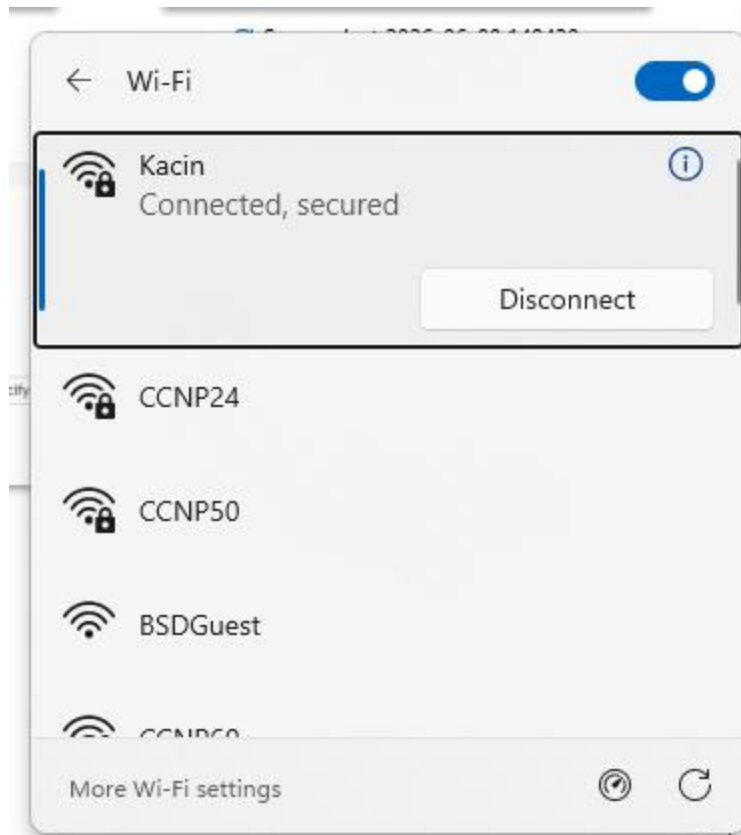
🌉 Bridge

Manual ⓘ

+

You can repeat this process again to create a 2.4 or 5 GHz network, make sure to create new address ranges.

Verify that it works by connecting to the new WiFi network.



Now to create the WPA2-Enterprise network repeat the process of creating a new SSID but instead of WPA2 Personal select WPA2-Enterprise.

Name  Kacin-Enterprises (Kacin-Radius)

Alias

Type  WiFi SSID

Traffic mode   Tunnel

Address

Addressing mode

Manual

IPAM

One-Arm Sniffer

IP/Netmask

10.0.1.1/255.255.255.0

Create address object matching subnet ☒

Name

 Kacin-Radius address

Destination

10.0.1.0/24

Secondary IP address



☒ DHCP Server

DHCP status

↑ Enabled

↓ Disabled

Address range

10.0.1.2-10.0.1.254

+

Netmask

255.255.255.0

Default gateway

Same as Interface IP

Specify

DNS server

Same as System DNS

Same as Interface IP

Specify

Lease time ⓘ

☒

604800

second(s)

WiFi Settings

SSID

Kacin-Enterprises

Client limit

☒

2

Broadcast SSID

☒

Beacon advertising

☒ Name

☐ Model

☐ Serial number

Security Mode Settings

Security mode

WPA2 Enterprise

Authentication

Local

RADIUS Server

Kacin-Radius-Server

As shown in the screenshot above select RADIUS Server as the method of authentication. Unlike the screenshot shown you will need to create a new server within the FortiGate system and physically.

To create a RADIUS Server, choose a Linux Device to run FreeRADIUS and connect it to the firewall. Next, configure the IP address of the device manually rather than automatically to make sure the device IP does not change when the firewall restarts, otherwise the server IP will have to be changed again.

Once the IP address has been manually set, navigate to the terminal emulator of your chosen Linux distribution. And type “sudo apt-get install freeradius” this will install the tool to make the laptop a RADIUS server.

```
260:~$ sudo apt-get install freeradius
```

Next, type the command “cd /etc/freeradius/3.0” as the root user. To become the root user, type the command “sudo -I”. This makes it so that you can access the files within that directory.

Next type “nano clients.conf” this lets you edit the files containing the RADIUS server client configurations.

Scroll until the “client private-network-2” is shown delete the hashtags that make the text obsolete and configure with a password and matching address range with the LAN network the RADIUS server is located in. text should appear a different color than the rest of the text if done correctly.

```
client private-network-2 {  
    ipaddr      = 198.168.1.1/24  
    secret      = Kacinrules123!  
}  
  
#####
```

Hit Ctrl + O to write/save and Ctrl + X to exit.

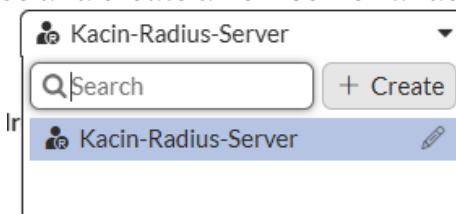
Next create a user by editing the users file by entering the command “nano users”.

Repeat the # deleting process after finding the example shown below.

```
bob    Cleartext-Password := "hello"  
       Reply-Message := "Hello, %{User-Name}"  
  
Kacin  Cleartext-Password := "Kacinrules123!"  
       Reply-Message := "Hello, %{User-Name}"
```

Write out the file and the RADIUS server configuration is done, now go back to the SSID configuration on the firewall.

Click the empty space and create a new server under WPA2 Enterprise.



Name the server and set the NAS IP as the FortiGate Firewall's interface IP facing the AP. And input the RADIUS Server IP in the Primary Server IP along with the password.

Edit RADIUS Server

Name

Authentication method **Default** Specify

NAS IP

Include in every user group ☒

Primary Server

IP/Name

Secret

Connection status ☒ Successful

Secondary Server

Confirm all configurations and find the WiFi network and enter the configured username and password.

← Wi-Fi ☒

Kacin-Enterprises
Secured

Enter your user name and password

☒ yooooo3.0

More Wi-Fi settings

← Wi-Fi ☒

Kacin-Enterprises
Connected, secured

☒ CCNP24

☒ CCNP50

☒ CCNP60

☒ BSC-Quint

More Wi-Fi settings

If the network shows a connection without internet create a firewall policy that allows traffic from the SSID to the WAN port of the firewall as shown below.

Create New Policy

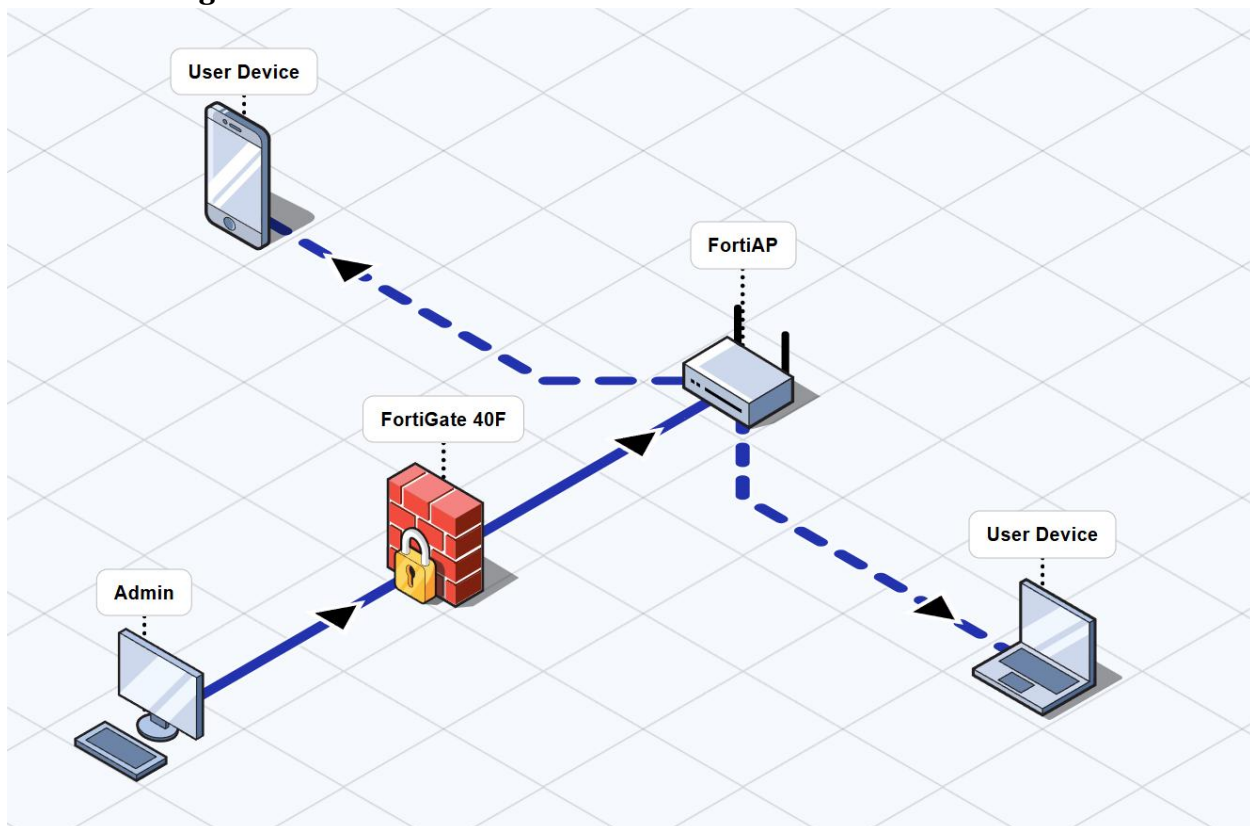
Name	WLAN Policy
Schedule	always
Action	☒ ACCEPT ☐ DENY
Incoming interface	Kacin-Enterprises (Kacin-Radius)
Outgoing interface	wan

Source & Destination [Show logic](#)

Source	Kacin-Radius address
User/group	
Destination	all
Service	ALL

The WPA2 Enterprise WLAN is now set up.

Network Diagram



Problems

I had some problems with setting up the RADIUS server as I did not know what to set the NAS IP and additionally the IP of the Radius Server had to be set manually for it to work properly as it kept taking the IP address of the DHCP server that leased an address to the firewall instead of getting a DHCP address from the firewall. Once the IP was set manually the FortiGate Firewall was able to connect to the RADIUS server and successfully authenticate users when connecting to the Wi-Fi network.

Another problem I had was that although I was connected to the Wi-Fi network, I was not able to get any data. I realized that this was because I had not updated the firewall policy to allow the source IP address from users connected to Wi-Fi to access the internet through the firewall. Once this was fixed a consistent internet connection was available and ready to use.

Conclusion

This lab was extremely helpful in helping to develop my skills and understanding of how to set up a secure wireless network using various methods of authentication via WPA2. It has also shown me the steps of security that a user needs to go through such as TLS Handshakes and Key Derivation methods to secure wireless communication as it can be accessed by malicious users without the need for a direct physical connection. All in all, it was very interesting and fun to do this lab as I got to learn about how we can access the data we use every day.